

To Pay a Ransom Is to Feed the Wolf:
The Evolution of Ransomware and What Organizations Can Do About It

Isabella Rios

Braiton Mendoza

Ivan Reyes

Department of Computer Science & Engineering

Texas A&M University

CSCE 701 – Fundamentals of Cybersecurity

Dr. Shreyas Kumar

July 25, 2026

Abstract

Ransomware has grown from a relatively simple form of malware into one of the most disruptive cybersecurity threats facing modern organizations. This paper uses a qualitative integrative literature review and comparative case-study analysis to examine ransomware's historical development, common access methods, organizational consequences, and mitigation strategies. The analysis prioritizes government guidance, regulatory filings, law-enforcement releases, and company reports, supplemented by peer-reviewed research and carefully qualified journalism. Four incidents—WannaCry, Colonial Pipeline, MGM Resorts, and Change Healthcare—were selected to represent different sectors, attack mechanisms, and forms of operational impact. The results show that no single technical failure explains ransomware harm; recurring factors include delayed patching, compromised credentials, weak identity verification, third-party concentration, and insufficiently tested recovery processes. The paper concludes that layered controls—especially phishing-resistant multifactor authentication, patching, network segmentation, secure backups, monitoring, and practiced incident response—reduce both the likelihood and impact of attacks, while ransom payment remains legally and operationally uncertain. Future research should use standardized incident data to compare control effectiveness, payment outcomes, and AI-assisted social engineering over time.

Introduction

Most modern organizations depend on computers, networks, cloud services, and digital records to complete normal operations. That dependence creates efficiency, but it also gives cybercriminals opportunities to create immediate business pressure. When attackers gain control of important systems, an organization may be unable to serve customers, process payments, communicate internally, or access essential records. Ransomware is especially disruptive because attackers make the loss of access visible and demand payment to restore operations or prevent stolen information from being released.

The FBI defines ransomware as malware that blocks access to files, systems, or networks and then demands payment for their return. More advanced versions can encrypt local files, connected drives, and systems across an organization's network. The FBI also notes that attacks can cause expensive business interruptions and the loss of critical data (Federal Bureau of Investigation, "Ransomware"). Ransomware is therefore more than a technical inconvenience: it is an organizational risk that can affect revenue, legal obligations, customer trust, employee productivity, and, in sectors such as health care and energy, public safety.

Although ransomware has evolved into a specialized criminal industry combining encryption, data theft, and social engineering, organizations can substantially reduce both the likelihood and impact of an attack through layered security controls and tested recovery planning. This paper explains that evolution, examines how criminals gain and expand access, analyzes the pressure ransomware creates through four real incidents, and evaluates practical defensive measures. The discussion is written for an introductory cybersecurity audience and therefore emphasizes the complete attack and response process rather than complicated code.

This review addresses three questions: How has ransomware evolved from isolated file encryption into organized, multi-stage extortion? What recurring weaknesses and consequences appear across the four selected incidents? Which defensive practices are most consistently supported by authoritative guidance and the case evidence? The paper does not attempt to estimate ransomware prevalence or establish statistical causation. Instead, it identifies recurring patterns and their practical implications for organizational risk management.

Related Work

Existing ransomware literature generally falls into three overlapping areas: historical and taxonomic studies of ransomware families, analyses of attacker tactics and payment ecosystems, and prevention or response frameworks. O’Kane et al. trace ransomware’s development from the AIDS Trojan through later cryptographic families. Oz et al. synthesize research on evolution, platforms, detection, and defense, while Paquet-Clouston et al. demonstrate how public blockchain records can support empirical analysis of ransomware payments. NIST and CISA complement that scholarship with operational risk-management and incident-response guidance (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”; Souppaya et al.). This paper integrates those strands and applies them to a cross-sector comparison of four prominent incidents.

What Is Ransomware?

Ransomware is a category of malicious software designed to deny a victim access to data or systems until a demand is met. In a traditional attack, the malware encrypts files using a key controlled by the attacker. The victim receives a ransom note explaining how to purchase cryptocurrency and send payment in exchange for a possible decryption key. Some older ransomware simply locked the screen or displayed a fake law-enforcement warning (O’Kane et

al.). Modern ransomware is usually more serious because it can affect shared drives, servers, backups, virtual machines, and cloud-connected resources.

Encryption is only one part of the modern threat. Many groups first copy sensitive information out of the network. They then threaten to publish customer records, employee information, contracts, medical data, or internal communications if the victim refuses to pay. NIST describes this as an additional extortion demand involving stolen information, separate from the demand to restore encrypted data (Souppaya et al.). This tactic is commonly called double extortion. Some campaigns add another layer by contacting customers or partners directly, creating additional pressure on the victim (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

A ransomware incident normally involves several stages. First, the attacker needs initial access, which may come from a phishing message, stolen password, exposed remote-access service, or an unpatched vulnerability. Next, the attacker studies the environment, searches for higher privileges, moves to other systems, and attempts to disable security tools. Data may be collected and copied before the final ransomware program is launched. This is important because the visible encryption event may be the last stage of a broader intrusion that has already allowed the attacker to expand access and collect data (Souppaya et al.).

The Evolution of Ransomware

Early ransomware was less organized than the attacks seen today. The 1989 AIDS Trojan, commonly identified as the first documented ransomware attack, was distributed through physical floppy disks, concealed filenames, and instructed victims to mail a payment. Its encryption design was weak enough to be reversed, and its payment process was slow and impractical (O’Kane et al.). Even so, the basic concept was present: deny access to information

and charge the victim to regain control. As internet access expanded, criminals gained faster ways to distribute malware and communicate with victims.

The later growth of cryptocurrency made ransom collection more practical. Cryptocurrency can be transferred across borders without relying on checks, cash, or conventional bank transfers. Transactions on public blockchains are not invisible, however, and law enforcement can sometimes trace and recover funds. Criminals therefore may move payments through multiple addresses and services to make attribution and recovery more difficult (O’Kane et al.; Paquet-Clouston et al.; United States Department of Justice, “Department of Justice Seizes”).

CryptoLocker, which began appearing in September 2013, helped establish the modern model of encrypting personal files and demanding cryptocurrency within a deadline. The U.S. Department of Justice described it as sophisticated ransomware that used cryptographic key pairs and commonly demanded Bitcoin payments (United States Department of Justice, “U.S. Leads Multi-National Action”). Later campaigns increasingly targeted organizational networks, where attackers could disrupt many devices and create greater pressure to restore operations quickly.

The 2017 WannaCry outbreak showed how ransomware could spread rapidly instead of depending only on one victim clicking one attachment. WannaCry used a weakness in Windows systems to move between computers, affecting organizations in many countries. Europol described the scale as unprecedented and coordinated an international response (Europol). The outbreak showed that patch management was not simply routine maintenance. A single missing security update could create widespread operational risk.

Modern ransomware is also shaped by Ransomware-as-a-Service, usually shortened to RaaS. In this model, a core group maintains ransomware tools and infrastructure while affiliates

gain access to victim networks and deploy the malware in exchange for fees or a share of ransom proceeds. CISA explains that this division of labor allows many loosely connected affiliates to use the same platform and can make attacks vary significantly in technique (Cybersecurity and Infrastructure Security Agency, “Understanding Ransomware Threat Actors”; Oz et al.). The model lowers the technical barrier to participation and allows different criminals to specialize in access, deployment, negotiation, or money laundering.

Common Attack Methods

Phishing remains one of the easiest ways to begin an intrusion. A message may appear to come from a coworker, vendor, delivery service, or technology department. The victim is encouraged to open an attachment, follow a link, sign into a fake website, or approve a request. The FBI explains that phishing and spoofing make communications appear trustworthy so victims will reveal information or download malicious software (Federal Bureau of Investigation, “Spoofing and Phishing”). Technical safeguards matter, but phishing demonstrates why users and verification procedures are also part of an organization’s security posture.

Stolen or reused passwords are another major entry point. Attackers may purchase credentials from earlier breaches, steal them through phishing, or repeatedly try common passwords against public services. Remote desktop services, virtual private network portals, email accounts, and cloud administration pages are especially valuable because they may provide direct access from the internet. Multifactor authentication can make stolen passwords less useful, but weaker implementations can still be abused through repeated approval requests, social engineering, or stolen session tokens. CISA therefore recommends phishing-resistant multifactor authentication, credential monitoring, account-lockout controls, and stronger identity and access

management for sensitive services (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

Unpatched software gives attackers another path. Security updates often fix weaknesses that are already publicly documented. Once a vulnerability becomes known, attackers can scan the internet for systems that have not been updated. CISA recommends regular vulnerability scanning and warns organizations not to expose services such as remote desktop directly to the internet without strong compensating controls (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”). This demonstrates that an organization may implement otherwise effective security controls and still remain vulnerable because a single unmanaged server or appliance was not maintained.

After getting inside, attackers often attempt privilege escalation and lateral movement. Privilege escalation means gaining permissions beyond the original compromised account. Lateral movement means moving from one system to another. Attackers search for administrator credentials, shared folders, backup systems, domain controllers, security consoles, and valuable databases. They may also create new accounts or scheduled tasks so access continues even if the first compromised password is changed (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

The final deployment is often timed for maximum disruption, such as overnight, during a weekend, or near a holiday. CISA, the FBI, and the NSA have reported an observed increase in ransomware activity during nonbusiness hours, especially on holidays and weekends (Cybersecurity and Infrastructure Security Agency, “BlackMatter Ransomware”). Attackers may disable endpoint protection, delete shadow copies, damage backups, and then deploy ransomware across many devices. By that point, removing the original phishing message is

insufficient. The organization must contain affected systems, determine how far the attacker moved, reset credentials, restore data, and verify that persistent access has been removed.

Why Organizations Are Targeted

Organizations are attractive ransomware targets because downtime creates financial and operational pressure. An individual may decide that losing personal files is not worth paying for, but an organization may lose substantial revenue or be unable to provide essential services while systems are unavailable. Hospitals need patient and scheduling systems, manufacturers need production and shipping systems, and retailers need payment terminals and inventory records. These dependencies give attackers leverage even when the encrypted information itself is not confidential.

Organizations also store valuable data. Customer records, health information, financial documents, legal files, credentials, and internal communications can be sold, misused, or used for additional extortion. Large organizations may offer larger potential payments, but smaller organizations are also vulnerable because they may have fewer security employees, older systems, limited monitoring, or backups that have never been tested. Attackers often select targets based on the combination of accessibility and potential profit rather than public prominence alone. This pattern is consistent with research describing ransomware as an economically motivated threat that succeeds when technical access can be converted into operational leverage (Oz et al.).

Third-party connections increase the possible impact. Organizations rely on software vendors, managed service providers, payment processors, and cloud platforms, so a weakness at one provider can interrupt many customers. The Change Healthcare attack demonstrated this concentration risk because health care providers across the United States depended on its claims

and payment systems. Cybersecurity risk therefore includes not only an organization's own devices but also the external services required for normal operations.

Methodology

This paper uses a qualitative integrative literature review combined with comparative case-study analysis. Sources were identified through targeted searches concerning ransomware history, initial access, extortion methods, organizational impact, recovery, and the four selected incidents. The review includes material available through July 25, 2026, while the historical discussion reaches back to the 1989 AIDS Trojan. Because this is an explanatory course research paper rather than an experimental study or systematic meta-analysis, its purpose is to synthesize credible evidence and identify recurring patterns rather than calculate prevalence or causal effect sizes.

Source selection followed an evidence hierarchy. Primary and authoritative sources—such as government guidance, law-enforcement releases, regulatory filings, and company reports—were preferred for incident facts, financial figures, and official recommendations. Peer-reviewed research was used for historical development, ransomware taxonomies, and payment-system analysis. Reputable journalism was used only when a material detail was not confirmed in an official source, and those claims were explicitly qualified as outside reporting. Sources were retained when they directly supported a claim, identified a responsible author or institution, provided a publication date, and offered a stable URL or DOI.

The four cases were selected purposively rather than randomly. WannaCry represents a global, worm-like outbreak and the consequences of delayed patching. Colonial Pipeline represents critical-infrastructure interdependence between business information systems and operational services. MGM Resorts represents social engineering, identity verification, and

visible hospitality disruption. Change Healthcare represents third-party concentration, health-sector dependency, and unusually large financial and privacy effects. Each case was examined across five themes: access or propagation, operational disruption, financial or privacy consequences, response and recovery, and the principal defensive lesson.

The method has limitations. Public accounts may omit sensitive investigative details, and threat-actor attribution can remain disputed or change as investigations continue. Financial figures are reported using the categories chosen by each organization and therefore are not perfectly comparable. The four cases are prominent and information-rich, so they illustrate different forms of ransomware risk but cannot establish how frequently the observed patterns occur across all incidents. These limitations are addressed by distinguishing confirmed facts from qualified reporting and avoiding statistical generalizations.

Results

The comparative analysis produced four recurring findings. First, ransomware incidents begin through different mechanisms, but failures in patching, credential protection, identity verification, or third-party governance repeatedly create usable access. Second, the largest business effects are not always caused by encryption alone; containment decisions, system interdependence, and uncertainty about attacker reach can also stop operations. Third, centralized service providers can spread consequences far beyond the initially compromised organization. Fourth, resilience depends on coordinated layers of prevention, detection, response, and recovery rather than a single security product.

Case Study Findings

WannaCry

WannaCry began spreading widely in May 2017 and affected organizations across the world. It combined ransomware with worm-like behavior, allowing it to move to other vulnerable Windows computers without requiring each user to open a separate malicious attachment. The outbreak disrupted hospitals, transportation companies, manufacturers, government offices, and other organizations. Europol called its international scale unprecedented and emphasized the need for a coordinated investigation (Europol).

The main cybersecurity lesson from WannaCry is the importance of patching and asset visibility. Microsoft had released security update MS17-010 in March 2017, before the May outbreak, to address the Windows vulnerability WannaCry later exploited (Microsoft Security Response Center). Many systems nevertheless remained unpatched, and some organizations were using older equipment or did not have a complete inventory of vulnerable devices. This shows why patching is both a technical and management issue: organizations need an inventory, assigned responsibility, testing procedures, maintenance windows, and a way to confirm that updates were installed.

Colonial Pipeline

In May 2021, Colonial Pipeline experienced a ransomware attack connected to the DarkSide group. The attack affected the company's business systems, after which Colonial disconnected certain systems used to monitor and control physical pipeline functions so they would not be compromised (United States Government Accountability Office). Colonial reported to the FBI that it paid approximately 75 bitcoin. The Department of Justice later announced that

investigators had traced and seized about 63.7 bitcoin connected to that payment (United States Department of Justice, “Department of Justice Seizes”).

Colonial Pipeline showed how an attack on business information systems can interrupt physical services and public confidence even when ransomware has not directly destroyed operational equipment. The company shut down pipeline operations while containing the incident and protecting connected systems. This distinction is important because cyber incidents often produce indirect consequences: uncertainty about what an attacker reached may itself require an organization to suspend operations until safety and integrity can be confirmed.

The case also shows the value of quickly involving law enforcement. Cryptocurrency should not be viewed as completely invisible. In this case, the FBI followed transactions on the public blockchain and obtained control of an address holding part of the payment. Recovery is not guaranteed, but early reporting can support investigation, intelligence sharing, and possible fund recovery (United States Department of Justice, “Department of Justice Seizes”).

MGM Resorts

MGM Resorts experienced a major cyberattack in September 2023. MGM’s own filings describe it as a “cybersecurity issue” involving unauthorized access, system shutdowns, operational disruptions, and the exposure of some customer information. Outside reporting linked the intrusion to ALPHV and Scattered Spider, groups associated with ransomware and data-extortion activity (MGM Resorts International; Reuters). This wording is more precise than treating every publicly reported detail as company-confirmed.

Bloomberg reported that the intrusion began with social engineering directed at MGM’s information technology service desk, based on information from a cybersecurity executive familiar with the investigation (Martin et al.). Because MGM did not confirm the initial access

method in its regulatory filing, the account should be treated as well-sourced reporting rather than an officially established fact. The incident nevertheless demonstrates a common weakness: support processes designed to restore access can be exploited when identity-verification procedures are not strong enough to resist persuasive impersonation.

MGM also shows that recovery involves more than restoring servers. The company reported that shutting down systems disrupted domestic properties and guest-facing services and negatively affected third-quarter performance (MGM Resorts International). Hotels depend on interconnected systems that customers expect to work immediately, so employees may need to use manual processes while guests experience delays. The business and reputational effects can therefore become visible before investigators fully understand the technical scope of an incident.

Change Healthcare

The February 2024 attack on Change Healthcare became one of the most serious health-sector cyber incidents in the United States. Change Healthcare supports pharmacy claims, medical claims, and payment processing. UnitedHealth Group isolated affected systems after discovering unauthorized access, but the shutdown disrupted services used by providers and pharmacies. HHS described the incident as having an unprecedented magnitude and widespread impact on patients and health care providers (United States Department of Health and Human Services).

The financial effects were also unusually large. UnitedHealth's 2024 annual filing reported \$2.2 billion in direct response costs and an estimated \$867 million in business disruption impacts. The company also provided more than \$9 billion in interest-free loans to support care providers while normal payment services were affected (UnitedHealth Group). These figures show why the cost of ransomware cannot be measured only by the ransom amount.

The incident also involved extremely sensitive personal and health information. HHS later reported that Change Healthcare estimated approximately 192.7 million individuals were affected (United States Department of Health and Human Services). The case shows the combined danger of operational dependence and concentrated data: one compromised service provider can create privacy, financial, and patient-care consequences across an entire industry.

Cross-Case Findings

Taken together, the four cases show that ransomware risk does not result from one type of failure. WannaCry illustrates patching and asset-visibility failures; Colonial Pipeline shows how compromised business systems can disrupt physical services; MGM demonstrates help-desk identity-verification risks in an extortion incident linked to ransomware actors; and Change Healthcare shows the systemic effects of third-party concentration. These differences support the paper's central argument that layered controls and tested recovery planning are more dependable than any single security product.

Across the cases, operational dependence was a decisive source of leverage. WannaCry transformed an unpatched vulnerability into widespread disruption through worm-like propagation. Colonial Pipeline suspended operations to protect connected systems even though the ransomware targeted business systems. MGM's containment measures disrupted guest-facing services, and Change Healthcare's central role in claims and payment processing magnified the outage across the health sector. These results indicate that dependency mapping, identity security, asset visibility, and recovery speed are business-continuity controls as well as technical cybersecurity controls (MGM Resorts International; Souppaya et al.; United States Government Accountability Office; UnitedHealth Group).

Discussion

Business Consequences of Ransomware

The most immediate consequence of ransomware is operational downtime. Employees may be unable to sign in, open files, communicate, process orders, or serve customers. Even systems that are not encrypted may be intentionally shut down to contain the incident or preserve evidence. Recovery is rarely as simple as turning everything back on. Teams must determine which systems are safe, rebuild devices, restore data, reset credentials, test applications, and reconnect services in a controlled order.

Financial losses can include lost sales, overtime, consultants, forensic investigation, legal advice, customer notification, credit monitoring, equipment replacement, and new security controls. Organizations may also face contract penalties, lawsuits, regulatory investigations, and higher insurance costs. These expenses can continue for months or years after normal operations return (Souppaya et al.; UnitedHealth Group).

Reputation is another concern. Customers may question whether the organization protected their data or communicated honestly, while business partners may require additional audits or security assurances. Employees can also lose confidence if they are asked to return to systems before the incident is fully understood. Communication must therefore balance transparency with the need to avoid releasing inaccurate information or interfering with an investigation.

Ransomware also creates decision pressure. Leaders may be forced to choose between paying, rebuilding, remaining offline, or restoring from backups that may be incomplete. Those choices happen while customers, regulators, employees, and the media are demanding answers. This is why incident response planning must involve executive leadership, legal counsel,

communications, finance, and operations rather than only the information technology department.

How Organizations Can Protect Themselves

There is no single product that stops every ransomware attack. The strongest approach is layered security, in which multiple controls make it harder for an attacker to enter, expand access, steal data, and complete encryption. NIST's ransomware profile organizes preparation around governing, identifying, protecting, detecting, responding, and recovering. This structure is useful because it recognizes that prevention alone is insufficient (Souppaya et al.).

The first step is knowing what the organization owns and depends on. Organizations should maintain an inventory of devices, software, cloud resources, accounts, vendors, and important data. Critical systems should have identified owners and recovery priorities. An unknown server cannot be patched reliably, and an unknown business dependency cannot be included in a recovery plan. These practices align with CISA and NIST guidance on asset management and recovery prioritization (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”; Souppaya et al.).

Multifactor authentication should be required for email, remote access, cloud administration, and other sensitive accounts. Strong multifactor authentication does not make account compromise impossible, but it creates an additional barrier beyond a password.

Organizations should also apply least privilege, meaning users receive only the access needed for their jobs. Administrator accounts should be separate from normal daily accounts, and unused accounts should be removed promptly. CISA further recommends phishing-resistant forms of multifactor authentication for email, remote access, and critical accounts (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

Patching and vulnerability management reduce opportunities for attackers to use known weaknesses. Updates should be prioritized based on exposure and risk, with internet-facing systems receiving special attention. Regular scanning can identify missing updates and misconfigurations. When a patch cannot be installed immediately, the organization should use temporary controls such as limiting network access, disabling the vulnerable feature, or increasing monitoring (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

Employee awareness training should focus on realistic behavior rather than only annual videos. Users need practice identifying suspicious messages, verifying unusual requests, reporting possible phishing, and responding to unexpected multifactor authentication prompts. Help-desk employees need especially strong identity-verification procedures because attackers may call while impersonating employees. A workplace where people can report mistakes quickly is safer than one where employees hide problems because they fear punishment (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

Network segmentation limits how far an attacker can move. Critical servers, user devices, backup systems, and operational technology should not all communicate freely. Firewalls and access rules can allow only necessary connections. Segmentation does not automatically stop ransomware, but it can prevent one compromised laptop from reaching every important system (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

Backups are essential, but they must be protected from the same accounts and networks used in normal operations. The FBI recommends regular backups and specifically warns that backups should not remain connected to the systems they protect (Federal Bureau of Investigation, “Ransomware”). Organizations should keep multiple copies, use offline or

immutable storage when possible, and test restoration. A backup that exists but cannot be restored within the required time is not an effective recovery plan.

Monitoring and endpoint detection can identify suspicious behavior before the final encryption stage. Examples include unusual administrator activity, large data transfers, security tools being disabled, new remote-access software, and rapid file changes. Alerts must be reviewed by trained personnel. A security tool cannot help if no one investigates its warnings or if logs are deleted before responders can use them (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”).

Finally, organizations need a written and practiced incident-response plan. CISA recommends quickly identifying and isolating affected systems, with priority given to systems essential to daily operations (Cybersecurity and Infrastructure Security Agency, “#StopRansomware Guide”). The plan should identify decision authority, emergency contacts, legal and insurance requirements, law-enforcement reporting procedures, communication responsibilities, backup restoration priorities, and evidence-preservation requirements. Tabletop exercises allow teams to practice difficult choices before a real emergency.

Should Organizations Pay the Ransom?

The decision to pay is complicated because an organization may be facing serious harm to customers, patients, or operations. However, payment does not guarantee that the attacker will provide a working decryption key, remove persistent access, or delete stolen information. The FBI does not support ransom payments because they encourage additional attacks and provide no guarantee that data will be returned (Federal Bureau of Investigation, “Ransomware”).

Payment can also create legal and sanctions concerns. The U.S. Treasury’s updated advisory warns that organizations and payment facilitators may face sanctions exposure when a

transaction involves a sanctioned person or entity and emphasizes prompt reporting and cooperation with government agencies (United States Department of the Treasury). An organization considering payment therefore needs legal advice, law-enforcement coordination, and careful review of the threat actor. This should not be an improvised decision made for the first time during an outage.

Preparation gives organizations more choices. Reliable backups, practiced recovery, segmented networks, cyber insurance, and emergency communication plans reduce the pressure to pay quickly. There may still be situations in which leaders believe payment is necessary, but a sound security strategy avoids making recovery depend primarily on a threat actor's willingness or ability to comply.

Emerging Threats and Policy Implications

Ransomware will continue changing because the business model is profitable and flexible. Criminals can shift among encryption, data theft, harassment, and service disruption depending on what creates the most pressure. Even when a specific brand or infrastructure is disrupted, developers, affiliates, and access brokers may move to other platforms without abandoning the broader Ransomware-as-a-Service model (Cybersecurity and Infrastructure Security Agency, "Understanding Ransomware Threat Actors"; Oz et al.).

Artificial intelligence may make phishing messages, translation, victim research, and social engineering more convincing and scalable. The FBI has warned that criminals are using AI to support targeted phishing and impersonation schemes (Federal Bureau of Investigation, "FBI Warns"). AI does not, however, remove the importance of basic defenses. Many successful intrusions still depend on exposed systems, weak passwords, missing patches, excessive

privileges, and slow detection, so organizations should address those recurring weaknesses while adapting training and verification procedures to AI-assisted deception.

Government and private-sector cooperation will remain important. Ransomware crosses national borders, uses cryptocurrency services, and targets shared technology. Law-enforcement operations, information sharing, sanctions, cryptocurrency tracing, and disruption of criminal infrastructure can raise costs for attackers and sometimes recover funds (United States Department of Justice, “Department of Justice Seizes”; United States Department of the Treasury). At the same time, each organization remains responsible for reducing its own exposure and preparing to recover.

Conclusion

Ransomware has evolved from small, limited attacks into organized criminal operations capable of interrupting major businesses and critical services. Modern attackers often steal data before encryption, use specialized partners, and pressure victims through public exposure. The cases of WannaCry, Colonial Pipeline, MGM Resorts, and Change Healthcare show that ransomware and related extortion incidents can affect hospitals, fuel distribution, hospitality, payments, privacy, and public confidence.

The research also shows that ransomware risk can be reduced. Organizations can improve resilience by knowing their assets, applying updates, protecting accounts with multifactor authentication, limiting privileges, training employees, segmenting networks, monitoring suspicious activity, securing backups, and practicing incident response. None of these measures is sufficient alone. Together, they make an attack more difficult and give the organization better options during recovery.

The title of this project reflects the larger problem with ransom payments: paying may help one victim in the moment, but it also supports a criminal system that will continue looking for new victims. The most effective response is not simply refusing to pay after an attack. It is building enough resilience before an attack that the organization is not forced to depend on the criminals who caused the disruption.

Future Work

Future ransomware research would benefit from standardized incident datasets that distinguish initial-access method, encryption, data theft, containment-related downtime, ransom demand, payment, recovery time, and total cost. Current public reports use inconsistent categories, which makes comparisons across organizations and sectors difficult. Building on existing survey and blockchain-payment research, future studies could combine regulatory disclosures, law-enforcement data, insurance records, and validated payment addresses to produce more comparable longitudinal evidence (Oz et al.; Paquet-Clouston et al.).

Additional empirical work should evaluate which controls most strongly affect outcomes rather than only whether organizations have adopted them. Useful questions include whether phishing-resistant multifactor authentication reduces help-desk and credential-based compromise, how network segmentation changes recovery time, how frequently immutable backups remain usable during real incidents, and whether tabletop exercises improve executive decisions under pressure.

Research should also track emerging forms of AI-assisted impersonation and the concentration risk created by shared technology providers. Controlled social-engineering studies, privacy-preserving incident sharing, and cross-sector comparisons could clarify whether AI changes attack success rates or mainly increase scale and speed. Continued study of payment

outcomes, sanctions exposure, and attacker adaptation after law-enforcement disruption would further connect technical, economic, and policy responses.

References

- Cybersecurity and Infrastructure Security Agency. “#StopRansomware Guide.” *CISA*, 19 Oct. 2023, www.cisa.gov/stopransomware/ransomware-guide. Accessed 25 July 2026.
- Cybersecurity and Infrastructure Security Agency. “BlackMatter Ransomware.” *CISA*, 18 Oct. 2021, www.cisa.gov/news-events/cybersecurity-advisories/aa21-291a. Accessed 25 July 2026.
- Cybersecurity and Infrastructure Security Agency. “Understanding Ransomware Threat Actors: LockBit.” *CISA*, 14 June 2023, www.cisa.gov/news-events/cybersecurity-advisories/aa23-165a. Accessed 25 July 2026.
- Europol. “WannaCry Ransomware.” *Europol*, 6 Nov. 2017, www.europol.europa.eu/wannacry-ransomware. Accessed 25 July 2026.
- Federal Bureau of Investigation. “FBI Warns of Increasing Threat of Cyber Criminals Utilizing Artificial Intelligence.” *FBI*, 8 May 2024, www.fbi.gov/contact-us/field-offices/sanfrancisco/news/fbi-warns-of-increasing-threat-of-cyber-criminals-utilizing-artificial-intelligence. Accessed 25 July 2026.
- Federal Bureau of Investigation. “Ransomware.” *FBI*, www.fbi.gov/how-we-can-help-you/scams-and-safety/common-frauds-and-scams/ransomware. Accessed 25 July 2026.
- Federal Bureau of Investigation. “Spoofing and Phishing.” *FBI*, www.fbi.gov/how-we-can-help-you/scams-and-safety/common-frauds-and-scams/spoofing-and-phishing. Accessed 25 July 2026.
- Martin, Andrew, Ryan Gallagher, and Katrina Manson. “MGM Resorts Hackers Broke In After Tricking IT Service Desk.” *Bloomberg*, 16 Sept. 2023,

www.bloomberg.com/news/articles/2023-09-16/mgm-resorts-hackers-broke-in-after-tricking-it-service-desk. Accessed 25 July 2026.

MGM Resorts International. *Current Report, Form 8-K*. U.S. Securities and Exchange Commission, 5 Oct. 2023, www.sec.gov/Archives/edgar/data/789570/000119312523251667/d461062d8k.htm. Accessed 25 July 2026.

Microsoft Security Response Center. “Customer Guidance for WannaCrypt Attacks.” *Microsoft*, 13 May 2017, www.microsoft.com/en-us/msrc/blog/2017/05/customer-guidance-for-wannacrypt-attacks/. Accessed 25 July 2026.

O’Kane, Philip, Sakir Sezer, and Domhnall Carlin. “Evolution of Ransomware.” *IET Networks*, vol. 7, no. 5, 2018, pp. 321–327, doi.org/10.1049/iet-net.2017.0207.

Oz, Harun, et al. “A Survey on Ransomware: Evolution, Taxonomy, and Defense Solutions.” *ACM Computing Surveys*, vol. 54, no. 11s, 2022, pp. 1–37, doi.org/10.1145/3514229.

Paquet-Clouston, Masarah, Bernhard Haslhofer, and Benoît Dupont. “Ransomware Payments in the Bitcoin Ecosystem.” *Journal of Cybersecurity*, vol. 5, no. 1, 2019, article tyz003, doi.org/10.1093/cybsec/tyz003.

Reuters. “MGM Resorts Says Regulators Probing September Cyberattack.” *Reuters*, 23 Feb. 2024, www.reuters.com/technology/cybersecurity/mgm-resorts-says-state-federal-regulators-probing-september-cyberattack-2024-02-23/. Accessed 25 July 2026.

Souppaya, Murugiah, et al. *Ransomware Risk Management: A Cybersecurity Framework 2.0 Community Profile*. NIST Interagency Report 8374 Rev. 1, National Institute of Standards and Technology, June 2026, doi.org/10.6028/NIST.IR.8374r1.

UnitedHealth Group Incorporated. *Annual Report, Form 10-K*. U.S. Securities and Exchange Commission, 2025,
www.sec.gov/Archives/edgar/data/731766/000073176625000063/unh-20241231.htm.
Accessed 25 July 2026.

United States Department of Health and Human Services. “Change Healthcare Cybersecurity Incident Frequently Asked Questions.” *HHS.gov*, updated 13 Aug. 2025,
www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/. Accessed 25 July 2026.

United States Department of Justice. “Department of Justice Seizes \$2.3 Million in Cryptocurrency Paid to the Ransomware Extortionists DarkSide.” *Justice.gov*, 7 June 2021,
www.justice.gov/archives/opa/pr/departments-justice-seizes-23-million-cryptocurrency-paid-ransomware-extortionists-darkside. Accessed 25 July 2026.

United States Department of Justice. “U.S. Leads Multi-National Action against ‘Gameover Zeus’ Botnet and ‘CryptoLocker’ Ransomware, Charges Botnet Administrator.” *Justice.gov*, 2 June 2014,
www.justice.gov/archives/opa/pr/us-leads-multi-national-action-against-gameover-zeus-botnet-and-cryptolocker-ransomware. Accessed 25 July 2026.

United States Department of the Treasury. “Treasury Takes Robust Actions to Counter Ransomware.” *U.S. Department of the Treasury*, 21 Sept. 2021,

home.treasury.gov/news/press-releases/jy0364. Accessed 25 July 2026.

United States Government Accountability Office. *Critical Infrastructure Protection: TSA Is Taking Steps to Address Some Pipeline Security Program Weaknesses*. GAO-21-105263, 27 July 2021, www.gao.gov/products/gao-21-105263. Accessed 25 July 2026.